codigo.py

Analise o arquivo em anexo passo a passo e determine ao final: este arquivo é benigno ou é um malware?

Worked for 1s >

Este arquivo é malware (ransomware).

Análise passo a passo

O código é uma implementação completa de ransomware para Windows (com suporte parcial a outros sistemas), rotulado internamente como “Liushen Ransomware PoC”. Não é um script benigno, de teste isolado ou de pesquisa legítima sem capacidade de dano. Abaixo está a estrutura e o comportamento real:

1. **Configuração e objetivos maliciosos**
   - Define valor de resgate (`RANSOM_AMOUNT = "5000"`), endereço Ethereum, extensão de arquivos criptografados (`.Liushen`), servidor C2 e parâmetros de threading/batch.
   - Gera chave mestra aleatória e ID de vítima.
2. **Anti-análise / evasão** (`AntiAnalysis`)
   - Detecção de VM (BIOS, MAC de VMware/VirtualBox etc.).
   - Detecção de debugger (API + timing).
   - Detecção de sandbox (uptime baixo, RAM < 2 GB, poucos cores, disco pequeno).
   - Em caso de detecção: atraso, saída silenciosa, “decoy” ou tentativa de crash.
     Isso é típico de malware real para evitar análise.
3. **Process Hollowing**
   - Cria processo legítimo (`svchost.exe`) suspenso, unmapa a imagem original, injeta o próprio código e altera o entry point.
     Técnica clássica de injeção/evasão usada por malware.
4. **Criptografia de arquivos** (`FileEncryptor`)
   - Percorre drives (ou home), seleciona extensões comuns (documentos, imagens, bancos de dados, código-fonte, backups etc.).
   - Exclui pastas de sistema para não quebrar o SO imediatamente.
   - AES-256-CBC por arquivo (chave derivada da mestra + IV).
   - Sobrescreve o original de forma “segura” (múltiplas passagens de dados aleatórios) e apaga o original.
   - Multithreading com limite de threads.
5. **Destruição de recuperação**
   - `ShadowCopyDeleter` : executa `vssadmin` , `wmic shadowcopy delete` , `diskshadow` e desativa recovery/bootstatus.

- `MBRLocker` (se admin): sobrescreve o MBR e grava mensagem de resgate no setor 1, tornando o boot inutilizável até pagamento/restauração.

6. **Desativação de segurança e processos**
   - Desativa Windows Defender, firewall, UAC, Windows Update.
   - Mata processos de Office, bancos de dados, backups, antivírus e ferramentas de análise (Task Manager, Process Explorer, Wireshark etc.).
7. **Persistência** (`Persistence`)
   - Registro (Run/RunOnce).
   - Pasta Startup.
   - Agendador de tarefas.
   - Serviço Windows (se admin).
   - Arquivos ocultos.
8. **Notas de resgate e exfiltração**
   - Cria `README_LIUSHEN.txt` em vários locais com instruções de pagamento e ID da vítima.
   - Tenta reportar via HTTP para C2, SMTP (desabilitado no código) ou salva chave/metadados localmente em pasta oculta.
9. **Fluxo de execução (`run`)**
   Anti-análise → escalonamento/process hollowing → desativar segurança → matar processos → apagar shadows → lock MBR → criptografar → notas → persistência → reportar.
10. **Entrada**
    Aceita `--encrypt` e tenta elevar privilégios. O modo decrypt está marcado como “não implementado no PoC”.

Conclusão

O arquivo **não é benigno**. É ransomware funcional: criptografa arquivos de usuário, impede recuperação (shadow copies + MBR), estabelece persistência, evade análise e exige resgate. Mesmo que o autor o chame de “PoC”, o código contém todas as capacidades necessárias para causar dano real e é tipicamente classificado como malware por antivírus e pesquisadores.

Não execute este código em nenhum sistema real. Análise estática como esta é suficiente para classificação; execução só deve ocorrer em ambiente isolado e controlado por profissionais de segurança.

Qual é a categoria principal deste malware?

Worked for 1s ›

Ransomware (especificamente *crypto-ransomware*).

A categoria principal é definida pelo comportamento central do código:

- Criptografa arquivos do usuário com AES-256 (extensão `.Liushen`).
- Exclui ou sobrescreve os originais.
- Impede recuperação (exclusão de Shadow Copies + alteração do MBR).
- Exibe notas de resgate exigindo pagamento em criptomoeda (Ethereum).
- Envia relatório da vítima (chave + ID) para um servidor C2.

As demais técnicas presentes (process hollowing, anti-VM/anti-debug, persistência, desativação de segurança etc.) são **recursos de suporte** comuns em ransomware moderno, mas não mudam a classificação principal. Elas servem para aumentar a chance de sucesso da criptografia e dificultar a análise/remoção.

Em resumo: a ameaça principal e a categoria oficial é **Ransomware**.

↘ Quais são os IOCs deste malware

↘ Como funciona o ransomware